

Governança Corporativa de Tecnologia da Informação: Um Estudo Aplicado sobre o Framework COBIT 2019

Emanuel Arlan Sousa Silva Ferreira¹, Filipe Santos Rodrigues de Jesus¹
Kaua Araujo Santos¹, Lucas de Almeida Borges¹, Rodrigo dos Santos Silva¹

¹Universidade Católica do Salvador (UCSAL)

Escola de Computação e Tecnologias da Informação

Bacharelado em Engenharia de Software

Avenida Professor Pinto de Aguiar, nº 2589, bairro Pituaçu, 41.740-090

Campus de Pituaçu – Salvador – BA – Brasil

{emanuel.ferreira, filipe.jesus, kauaaraujo.santos,
lucasalmeida.borges, rodrigasantos.silva}@ucsal.edu.br

Abstract. *This paper analyzes the COBIT 2019 framework in corporate Information and Technology (I&T) Governance, marking 30 years of evolution by ISACA. It examines the distinction between governance and management, core principles, 5 architectural domains (EDM, APO, BAI, DSS, MEA), and 7 governance components. Acting as a strategic umbrella, COBIT orchestrates frameworks such as ITIL, ISO/IEC 27001, TOGAF, and PMBOK. Supported by Design Factors and the CMMI capability model, it customizes adaptive governance systems. Finally, an empirical case study of the Central Bank of Nigeria (CBN) demonstrates how shared governance and integrated risk reporting transform operational firefighting into sustainable corporate value.*

Resumo. *Este artigo analisa o framework COBIT 2019 na Governança Corporativa de Informação e Tecnologia (I&T), marco de 30 anos de evolução pela ISACA. Examina-se a distinção entre governança e gestão, princípios fundamentais, os 5 domínios arquiteturais (EDM, APO, BAI, DSS, MEA) e os 7 componentes habilitadores. Como guarda-chuva estratégico, o COBIT orquestra modelos como ITIL, ISO/IEC 27001, TOGAF e PMBOK. Por meio dos Fatores de Design e da escala de capacidade CMMI, demonstra-se a personalização de sistemas adaptativos. Por fim, o caso do Banco Central da Nigéria (CBN) ilustra como a governança compartilhada e a gestão de riscos transformam operações reativas em valor corporativo sustentável.*

1. Introdução

A crescente dependência das organizações em relação aos ativos de Tecnologia da Informação e Comunicação (TIC) transformou a TI de uma função meramente operacional em um componente estratégico central para a sobrevivência, inovação e competitividade empresarial (WEILL; ROSS, 2006; FERNANDES; ABREU, 2014). Nesse cenário complexo, a governança corporativa de TI estabelece os mecanismos de liderança, estruturas organizacionais e fluxos decisórios que garantem que as decisões e os investimentos tecnológicos sustentem e ampliem os objetivos institucionais do negócio.

Completando três décadas de contínuo aprimoramento desde sua concepção original em 1996, o framework *COBIT 2019* (*Control Objectives for Information and Related Technologies*), desenvolvido pela ISACA, consolidou-se internacionalmente como o arcabouço mais abrangente para a governança e a gestão de Informação e Tecnologia (I&T) (ISACA, 2018c). Diferente de modelos estáticos e puramente prescritivos, o COBIT 2019 destaca-se pela introdução de Fatores de Design (*Design Factors*) e princípios customizáveis, permitindo desenhar sistemas de governança sob medida para as necessidades de negócio e perfis de risco específicos de cada organização (ISACA, 2018a). Além disso, atua como um meta-modelo estruturante (“guarda-chuva estratégico”) que harmoniza e orquestra frameworks especializados do setor, tais como ITIL, ISO/IEC 27001, TOGAF e PMBOK (FEELY, 2007; ISO/IEC, 2024).

1.1. Objetivos

1.1.1. Objetivo Geral

Analisar a aplicação dos princípios, domínios arquiteturais e objetivos de governança e gestão do COBIT 2019 na estruturação e operacionalização de um modelo de Governança de TI corporativo.

1.1.2. Objetivos Específicos

- Compreender a distinção conceitual e prática entre governança corporativa e gestão operacional de tecnologia segundo o COBIT 2019 e a norma ISO/IEC 38500;
- Explorar a evolução histórica do modelo e seus 5 domínios fundamentais (EDM, APO, BAI, DSS e MEA), compreendendo suas perguntas orientadoras e os 7 componentes habilitadores do sistema de governança;
- Investigar a interoperabilidade do COBIT 2019 com normas e frameworks setoriais de mercado (ITIL, ISO/IEC 27001, TOGAF e PMBOK);
- Analisar o papel dos fatores de design e da escala de capacidade CMMI na personalização e avaliação contínua dos processos de governança;
- Avaliar a aplicabilidade empírica do framework por meio do estudo de caso de reestruturação da governança de TI no Banco Central da Nigéria (*Central Bank of Nigeria* – CBN).

2. Referencial Teórico

2.1. Conceito e Distinção entre Governança e Gestão de TI

De acordo com Weill e Ross (2006), a governança de TI consiste na especificação dos direitos de decisão e no framework de responsabilidades projetado para estimular comportamentos desejáveis na utilização corporativa da tecnologia da informação. Trata-se, portanto, de definir quem possui autoridade para deliberar sobre investimentos, arquitetura e riscos, superando o paradigma simplista da tecnologia enquanto centro isolado de custos operacionais.

A norma internacional ISO/IEC (2024) e a literatura especializada (FERNANDES; ABREU, 2014) enfatizam a separação formal entre os papéis de governança e de

gestão. A governança situa-se na esfera de responsabilidade do conselho de administração e da alta liderança executiva, incumbida de responder fundamentalmente “o quê” e “por quê” a organização demanda em recursos tecnológicos. Suas responsabilidades nucleares condensam-se na tríade: avaliar opções e demandas estratégicas, direcionar prioridades e investimentos, e monitorar continuamente os resultados obtidos.

Por sua vez, a gestão de TI atua no nível tático e operacional, cabendo aos gestores e equipes técnicas responder “como” as diretrizes corporativas serão concretizadas. Suas atividades envolvem planejar, construir, executar e monitorar as rotinas diárias de tecnologia. Configura-se, assim, um fluxo bidirecional e dinâmico: a governança estabelece as diretrizes e as fronteiras de decisão para a gestão, e a gestão reporta indicadores de desempenho e conformidade de volta aos órgãos deliberativos (WEILL; ROSS, 2006; ISACA, 2018c).

2.2. Origem e Evolução Histórica do COBIT

O *Control Objectives for Information and Related Technologies* (COBIT) foi concebido em 1996 pela *Information Systems Audit and Control Association* (ISACA) com o intuito inicial de fornecer um guia estruturado para que auditores financeiros pudessem avaliar controles internos em ambientes de processamento computacional em rápida expansão. Ao longo de três décadas de aprimoramento contínuo, o framework transcendeu a auditoria estrita para consolidar-se como o principal padrão global de governança e gestão de Informação e Tecnologia (I&T) corporativa:

- **COBIT 1 (1996) – Auditoria:** Foco na criação de uma biblioteca de objetivos de controle para orientar auditorias financeiras e de sistemas contábeis;
- **COBIT 2 (1998) – Controle:** Expansão dos objetivos e introdução de orientações detalhadas sobre a avaliação de controles tecnológicos corporativos;
- **COBIT 3 (2000) – Gestão:** Transição conceitual para um framework de gestão de TI, incorporando métricas de desempenho e fatores críticos de sucesso;
- **COBIT 4 e 4.1 (2005/2007) – Governança, Valor e Risco:** Consolidação definitiva como modelo abrangente de governança corporativa de TI, articulando-se progressivamente aos modelos *Val IT* (geração e sustentação de valor dos negócios) e *Risk IT* (gestão e apetite ao risco corporativo);
- **COBIT 5 (2012) – Integração Unificada:** Unificação formal do COBIT 4.1, *Val IT* e *Risk IT* em um arcabouço holístico de cinco princípios e sete habilitadores, aproximando a estratégia empresarial da estratégia de tecnologia;
- **COBIT 2019 (2018) – Adaptabilidade e Dinamismo:** Lançado ao final de 2018 e denominado COBIT 2019, introduziu os Fatores de Design (*Design Factors*), permitindo a criação de sistemas de governança sob medida, atualizações periódicas abertas e métricas de capacidade alinhadas ao CMMI (ISACA, 2018c; ISACA, 2018a).

2.3. Princípios Norteadores: Sistema versus Framework de Governança

A arquitetura do COBIT 2019 estabelece uma distinção rigorosa entre os princípios que sustentam o **sistema de governança** implementado na organização e os princípios que orientam o próprio **framework de governança** desenvolvido pela ISACA (ISACA, 2018c):

1. Princípios do Sistema de Governança:

- *Fornecer valor aos stakeholders*: Buscar o equilíbrio dinâmico entre a realização de benefícios, a otimização de riscos e a otimização de recursos;
- *Abordagem holística*: Estruturar a governança integrando componentes interconectados de naturezas diversas;
- *Sistema dinâmico de governança*: Reagir com agilidade quando fatores de design estratégicos ou tecnológicos são alterados;
- *Governança distinta da gestão*: Preservar a separação conceitual e operacional entre avaliação/direcionamento e planejamento/execução;
- *Adaptado às necessidades organizacionais*: Customizar o sistema com base nos parâmetros e no perfil exclusivo de cada negócio;
- *Sistema de ponta a ponta (fim-a-fim)*: Cobrir todas as funções corporativas de processamento de informação, não se restringindo ao departamento de TI.

2. Princípios do Framework de Governança:

- *Baseado em um modelo conceitual*: Estruturado sobre componentes lógicos e relações formais de governança;
- *Aberto e flexível*: Modular para acomodar novos conceitos, tecnologias emergentes e atualizações sem desconstruir o núcleo estrutural;
- *Alinhado aos principais padrões*: Harmonizado com normas internacionais consolidadas, atuando de maneira interoperável.

2.4. Estrutura Arquitetural do COBIT 2019: Domínios e Componentes de Governança

Para viabilizar a governança sistêmica e superar a visão isolada da TI, o COBIT 2019 estrutura a governança corporativa de informação e tecnologia como um ecossistema integrado às metas de negócio (WEILL; ROSS, 2006; FEELY, 2007; ISACA, 2018c). Seu propósito primordial consiste em assegurar a geração contínua de valor corporativo mediante a manutenção do denominado triplo equilíbrio: a realização de benefícios, a mitigação e otimização de riscos, e a utilização racional e otimizada de recursos organizacionais (ISACA, 2018c).

O núcleo do modelo organiza 40 objetivos fundamentais de governança e gestão, distribuídos em cinco domínios delimitados por perguntas norteadoras que demarcam as esferas de autoridade e atuação executiva (ISACA, 2018b):

1. **EDM (*Evaluate, Direct and Monitor*)**: Domínio exclusivo de governança corporativa, de responsabilidade direta do conselho de administração e da alta direção executiva (ISACA, 2018b). Responde à questão fundamental: “*Estamos direcionando a TI correta?*”. Sua atuação consiste em avaliar propostas e diretrizes estratégicas, deliberar sobre quais investimentos e iniciativas tecnológicas efetivamente agregam valor à organização, direcionar prioridades corporativas e monitorar o cumprimento de metas de conformidade e agregação de valor aos *stakeholders*.
2. **APO (*Align, Plan and Organize*)**: Primeiro domínio da gestão técnica, voltado ao nível tático. Responde à diretriz: “*Qual é o plano e a estrutura organizacional necessária?*”. Abrange a definição da arquitetura estratégica de TI, gestão do portfólio corporativo, planejamento orçamentário, gestão do capital humano, inovação e avaliação sistemática de riscos operacionais (ISACA, 2018b).

3. **BAI (*Build, Acquire and Implement*)**: Domínio de gestão que responde à pergunta: “*Como construímos, adquirimos e entregamos as mudanças?*”. Foca na identificação de requisitos, concepção e desenvolvimento de novas aplicações ou aquisição e contratação de soluções tecnológicas no mercado, gestão de programas e projetos, além da administração controlada de mudanças organizacionais e tecnológicas.
4. **DSS (*Deliver, Service and Support*)**: Domínio operacional responsável por responder: “*Como operamos com estabilidade e suporte no dia a dia corporativo?*”. Concentra a sustentação e o funcionamento operacional cotidiano dos serviços, garantia de continuidade operacional, gestão da segurança da informação e tratamento célere de incidentes e problemas no dia a dia produtivo.
5. **MEA (*Monitor, Evaluate and Assess*)**: Domínio de controle que responde à questão: “*O ambiente está funcionando adequadamente e em conformidade regulatória?*”. Conduz o acompanhamento contínuo dos resultados obtidos, a medição do desempenho interno dos processos de TI, a autoavaliação contínua dos controles e a garantia de conformidade do ecossistema perante exigências legais, normas externas e órgãos reguladores.

Essa segregação consolida a premissa de que a governança direciona e delimita as fronteiras de decisão cabíveis à alta administração, enquanto a gestão cuida do planejamento e da execução técnica, retroalimentando métricas e relatórios aos órgãos colegiados (WEILL; ROSS, 2006; ISACA, 2018c).

Para ilustrar a dinâmica sequencial e a interdependência prática desses cinco domínios na realidade corporativa, pode-se tomar o exemplo da implantação de um novo sistema organizacional. Nesse ciclo integrado: (1) no domínio **EDM**, a alta direção avalia a necessidade da iniciativa e direciona se a adoção do sistema é pertinente e justificada perante os objetivos da empresa; (2) no domínio **APO**, estrutura-se o planejamento tático, a arquitetura e a alocação de recursos necessários; (3) no domínio **BAI**, a solução é desenvolvida ou contratada junto a fornecedores, gerenciando-se sua implementação; (4) no domínio **DSS**, a aplicação entra em regime de produção, cabendo a sustentação operacional dos serviços, a segurança e a resolução de incidentes rotineiros; e (5) no domínio **MEA**, acompanha-se o desempenho contínuo do sistema em operação, atestando se os resultados alcançados atendem aos requisitos de conformidade e às metas do negócio. Dessa maneira, os cinco domínios asseguram que a tecnologia não opere de forma isolada, mas articulada em um fluxo contínuo de valor.

Todavia, a consecução desses 40 objetivos requer mais do que processos procedimentais. O COBIT 2019 estipula que a governança sustentável não depende unicamente de fluxos operacionais, mas sim da integração equilibrada de **sete componentes habilitadores** (*components of a governance system*), materializando a abordagem holística do framework (ISACA, 2018c; ISACA, 2018b):

- **Processos**: Conjuntos estruturados de práticas e fluxos de atividades que organizam o trabalho e transformam entradas em saídas mensuráveis de governança;
- **Estruturas Organizacionais**: Comitês executivos, conselhos e papéis formais investidos de autoridade deliberativa, definindo as instâncias responsáveis pela tomada de decisão na organização (WEILL; ROSS, 2006);

- **Princípios, Políticas e Procedimentos:** Regras e diretrizes corporativas que estabelecem as normas de conduta e traduzem as intenções estratégicas da governança em rotinas operacionais diárias;
- **Informação:** Fluxos informacionais estruturados, cuja integridade, confiabilidade e disponibilidade sustentam deliberações assertivas do negócio;
- **Cultura, Ética e Comportamento:** Fatores comportamentais, conduta ética individual e coletiva, atitudes e valores compartilhados que moldam a maneira como os indivíduos agem dentro da empresa;
- **Pessoas, Habilidades e Competências:** Capital humano devidamente preparado e qualificado, dotado das competências técnicas, analíticas e gerenciais necessárias à condução das funções;
- **Serviços, Infraestrutura e Aplicações:** Infraestrutura tecnológica, telecomunicações, sistemas corporativos e aplicações que viabilizam o processamento e a governança de I&T.

A necessidade dessa integração holística evidencia-se na constatação prática de que a simples aquisição de tecnologias avançadas ou sistemas de ponta torna-se inócua se o corpo funcional não possuir a capacitação adequada para operá-los, se inexistirem políticas formais que disciplinem seu funcionamento, ou se faltarem estruturas organizacionais com papéis decisórios bem delimitados. Assim, a atuação articulada dos sete componentes cumpre o papel fundamental de harmonizar tecnologia, pessoas e processos para funcionarem de maneira coesa na sustentação da governança corporativa de TI (FERNANDES; ABREU, 2014; ISACA, 2018c).

2.5. Benefícios Corporativos, Aplicabilidade e o COBIT como “Guarda-Chuva Estratégico”

A institucionalização de um modelo de governança baseado no COBIT 2019 combate ativamente problemas crônicos que historicamente desgastam a relação entre as diretorias executivas e os setores técnicos, tais como o desalinhamento estratégico, investimentos sem retorno econômico verificável, proliferação de sistemas paralelos sem suporte (*shadow IT*), lentidão decisória e incidentes operacionais sem controle (FERNANDES; ABREU, 2014; FEELY, 2007).

Organizações maduras que implementam o COBIT 2019 reportam cinco benefícios corporativos fundamentais (ISACA, 2018c):

1. **Alinhamento Estratégico Bidirecional:** Assegura convergência contínua entre os planos de expansão do negócio e as prioridades de investimento tecnológico;
2. **Gestão Proativa de Riscos e Segurança:** Tratamento preventivo de vulnerabilidades cibernéticas e mitigação de impactos sobre a continuidade das operações;
3. **Conformidade Regulatória e Auditabilidade:** Agilidade e rastreabilidade para responder a auditorias independentes, órgãos de controle governamentais e leis de proteção de dados;
4. **Tomada de Decisão Baseada em Métricas:** Adoção sistemática de indicadores-chave de desempenho (KPIs) e metas auditáveis, afastando juízos puramente subjetivos;
5. **Estabelecimento de Linguagem Comum:** Alinhamento terminológico entre o conselho deliberativo executivo e os gestores técnicos de tecnologia, suprimindo o jargão excessivo e aproximando a TI dos centros de poder.

Em relação à aplicabilidade, o framework demonstra máxima aderência em setores sob elevada vigilância regulatória (instituições financeiras, órgãos governamentais, saúde, telecomunicações e energia) e em momentos de transição corporativa – como processos de fusões e aquisições, rápida expansão de infraestrutura, imposição de resoluções de órgãos de controle ou crises desencadeadas por incidentes técnicos recorrentes (FERNANDES; ABREU, 2014).

Sob o aspecto arquitetural, o COBIT 2019 não busca substituir normas especializadas nem opera em regime concorrencial. Conforme sintetizado por Feely (2007) e corroborado por Fernandes e Abreu (2014), o COBIT posiciona-se como um “**guarda-chuva estratégico**” (ou meta-modelo de governança), responsável por prover direcionamento, priorização e controle de alto nível, enquanto delega a execução detalhada a frameworks operacionais consolidados no mercado:

- **ITIL (*Information Technology Infrastructure Library*)**: Fornece as melhores práticas para a gestão do ciclo de vida dos serviços e operação contínua de TI, preenchendo as rotinas táticas e operacionais dos domínios APO e DSS (FERNANDES; ABREU, 2014);
- **ISO/IEC 27001 e ISO/IEC 27002**: Estabelecem diretrizes prescritivas e controles técnicos para a implementação do Sistema de Gestão de Segurança da Informação (SGSI), garantindo a proteção e integridade dos ativos informacionais;
- **TOGAF (*The Open Group Architecture Framework*)**: Disciplina o desenho e a padronização das arquiteturas corporativas de tecnologia, interligando lógica de negócios, dados, aplicações e infraestrutura;
- **PMBOK (*Project Management Body of Knowledge*)**: Padroniza a condução de projetos e gerenciamento de portfólio corporativo, operacionalizando as entregas do domínio BAI;
- **ISO/IEC 38500:2024**: Norma basilar internacional que rege os princípios de governança corporativa de TI para órgãos diretivos, cujas diretrizes convergem integralmente com as premissas do COBIT 2019 (ISO/IEC, 2024).

Essa interoperabilidade garante coerência estratégica transversal a toda a corporação sem desestruturar as especializações técnicas requeridas em cada área operacional (ISACA, 2018c; FEELY, 2007).

3. Metodologia

O presente estudo adota uma abordagem metodológica qualitativa, de natureza exploratória e descritiva, articulada a partir de pesquisa bibliográfica e análise documental sistemática (FERNANDES; ABREU, 2014). A base conceitual fundamenta-se nas publicações normativas oficiais da ISACA para o COBIT 2019 (ISACA, 2018c; ISACA, 2018b; ISACA, 2018a), complementada por literatura acadêmica de referência em governança corporativa de TI (WEILL; ROSS, 2006; FEELY, 2007) e normas internacionais vigentes (ISO/IEC, 2024).

O percurso analítico do trabalho estruturou-se em duas frentes complementares:

1. **Análise do Fluxo Metodológico de Design do COBIT 2019**: Aderência às quatro etapas normativas descritas no *COBIT 2019 Design Guide* (ISACA, 2018a):

- *Etapa 1 – Compreensão do Contexto Empresarial e Estratégia*: Mapeamento de estratégias, metas corporativas e apetite ao risco;
 - *Etapa 2 – Determinação do Escopo Inicial*: Ponderação preliminar dos Fatores de Design para ranqueamento de objetivos de governança e gestão;
 - *Etapa 3 – Refinamento do Escopo do Sistema*: Calibração das prioridades a partir de ameaças cibernéticas, exigências de conformidade regulatória e maturidade do modelo de fornecimento;
 - *Etapa 4 – Conclusão e Desenho do Sistema Customizado*: Estabelecimento dos níveis-alvo de capacidade segundo a escala CMMI e elaboração de planos de ação viáveis.
2. **Investigação Empírica por Estudos de Caso**: Confronto entre os modelos prescritivos e a dinâmica organizacional real por meio da análise de casos documentados na literatura internacional recente:
- A aplicação do *Design Toolkit* e avaliação da escala de capacidade de processos de segurança (DSS05) na operadora logística portuária PT. Pelindo TPK Bitung (TANGKA; LOMPOLI, 2023);
 - O estudo de caso longitudinal de reestruturação da governança de TI no Banco Central da Nigéria (*Central Bank of Nigeria* – CBN) (TEITLER-SANTULLO, 2022), avaliando os impactos pré e pós-implementação do COBIT sobre a postura operacional, direitos decisórios, alinhamento estratégico, realização de valor e gestão integrada de riscos.

4. Desenvolvimento e Análise

4.1. Aplicação dos Fatores de Design

O COBIT 2019 inovou substancialmente em relação às versões anteriores ao introduzir os Fatores de Design (*Design Factors*), superando a ideia de que um modelo de governança deve ser aplicado de forma genérica e prescritiva (ISACA, 2018a). Os Fatores de Design atuam como moduladores analíticos que influenciam a priorização relativa e os níveis-alvo de capacidade para cada um dos 40 objetivos de governança e gestão. O framework especifica 11 fatores categorizados pelo contexto corporativo:

1. **Estratégia Empresarial**: Foco primário da organização (inovação/diferenciação, liderança em custos, foco no cliente ou estabilidade operacional);
2. **Metas de Negócio**: Objetivos estratégicos globais que se desdobram nas metas de alinhamento de TI;
3. **Perfil de Risco**: Apetite institucional ao risco e nível de exposição operacional e cibernética;
4. **Problemas Relacionados a I&T**: Histórico recente de incidentes, falhas de segurança ou custos descontrolados de tecnologia;
5. **Cenário de Ameaças**: Nível de hostilidade e complexidade do ecossistema cibernético externo;
6. **Requisitos de Conformidade**: Pressões regulatórias impostas pelo setor de atuação (e.g., leis setoriais, BACEN, LGPD/GDPR);
7. **Papel da TI**: Função estratégica atribuída à tecnologia (suporte, fábrica, transição ou pilar nuclear estratégico);
8. **Modelo de Fornecimento de TI**: Utilização de serviços em nuvem, terceirização intensiva ou infraestrutura própria compartilhada;

9. **Métodos de Implementação de TI:** Metodologias predominantes de desenvolvimento e entrega (DevOps, métodos ágeis ou tradicional em cascata);
10. **Estratégia de Adoção de Tecnologia:** Postura frente a inovações (pioneiro inovador, seguidor rápido ou conservador);
11. **Tamanho da Empresa:** Porte organizacional, complexidade geográfica e número de colaboradores.

Na prática operacional, a avaliação quantitativa desses fatores viabilizada pelo *COBIT 2019 Design Toolkit* permite derivar uma matriz de governança customizada. Em estudos empíricos recentes, como a investigação conduzida por Tangka e Lompoliu (2023) em uma operadora logística portuária (*PT. Pelindo TPK Bitung*), a aplicação dos Fatores de Design demonstrou que ambientes submetidos a regimes severos de conformidade e riscos operacionais priorizam fortemente objetivos de segurança da informação e entrega de serviços operacionais, notadamente os objetivos do domínio DSS (*Deliver, Service and Support*).

4.2. Modelo de Capacidade de Processos

Para a medição e avaliação evolutiva dos processos de governança, o COBIT 2019 adota o modelo de capacidade baseado na escala internacional do CMMI (*Capability Maturity Model Integration*), estruturado em níveis contínuos de 0 a 5 (ISACA, 2018c):

- **Nível 0 – Incompleto:** O processo não atinge seu propósito essencial; práticas básicas não são executadas ou são totalmente desestruturadas;
- **Nível 1 – Inicial:** O processo atinge seu propósito geral por meio de um conjunto básico e informal de atividades executadas;
- **Nível 2 – Gerenciado:** O processo é devidamente planejado, executado, monitorado e corrigido, gerando produtos de trabalho controlados;
- **Nível 3 – Definido:** O processo é formalmente documentado, institucionalizado e padronizado em nível corporativo;
- **Nível 4 – Quantitativamente Gerenciado:** O processo é guiado por métricas estatísticas e quantitativas de desempenho e qualidade;
- **Nível 5 – Em Otimização:** O processo fundamenta-se na melhoria contínua, análise preditiva e busca ativa por inovações tecnológicas.

A medição de capacidade fornece um mapa claro de lacunas corporativas (*gap analysis*). Como verificado por Tangka e Lompoliu (2023), a avaliação empírica do processo *DSS05 (Gerenciar Serviços de Segurança)* revelou nível 3 de capacidade (processo definido), indicando que os controles operacionais estavam implementados com sucesso, mas sinalizando a necessidade premente de aprimorar a formalização das políticas de auditoria periódica e conformidade normativa para alcançar patamares quantitativos superiores.

4.3. Estudo de Caso Aplicado: Reestruturação da Governança de TI no Banco Central da Nigéria (*Central Bank of Nigeria – CBN*)

Para examinar o comportamento prático do COBIT em organizações caracterizadas por extrema complexidade estrutural e pressão regulatória, analisa-se o caso de reestruturação de governança vivenciado pelo Banco Central da Nigéria (*Central Bank of Nigeria – CBN*), reportado na literatura de governança da ISACA (TEITLER-SANTULLO, 2022).

Como instituição responsável pela estabilidade financeira e monetária da maior economia do continente africano, o CBN operava em 2015 com uma estrutura capilarizada em 27 filiais operacionais, um quadro funcional de aproximadamente 9.000 servidores públicos e um departamento de TIC com mais de 300 especialistas dedicados.

4.3.1. Diagnóstico do Cenário Operacional Crítico (2015)

Conforme preconizado pelos acordos regulatórios bancários internacionais (como o Acordo da Basileia), o CBN mantinha certificações operacionais na norma ISO/IEC 27001 e executava rotinas de atendimento de serviços balizadas pelo catálogo do ITIL (TEITLER-SANTULLO, 2022). Apesar da vigência dessas certificações técnicas, a organização padecia de severos impasses na gestão e governança de tecnologia:

- **Operação Reativa Permanente:** A equipe de TI atuava em constante regime de emergência (“apagando incêndios”), desprovida de planejamento de capacidade operacional e sem previsibilidade para antecipar demandas;
- **Prática Generalizada de *Shadow IT*:** Os departamentos e unidades de negócio contornavam rotineiramente a diretoria de TI, submetendo propostas de aquisição de novos sistemas tecnológicos diretamente ao conselho deliberativo executivo do banco;
- **Ausência de Triagem Técnica e Imposição de Mandatos:** Projetos eram aprovados unilateralmente pelo conselho sem consulta prévia quanto à viabilidade na infraestrutura instalada ou dimensionamento das equipes de desenvolvimento, gerando metas e prazos tecnicamente inexecutáveis;
- **Fracasso na Realização de Valor:** Sistemas contratados eram entregues com atrasos vultosos e estouros orçamentários, sem que houvesse qualquer mecanismo para mensurar se os benefícios econômicos previstos nos estudos de viabilidade haviam sido concretizados após a entrada em produção (TEITLER-SANTULLO, 2022; WEILL; ROSS, 2006).

4.3.2. Estratégia Metodológica e Intervenção de Governança (2016)

Diante da perda de credibilidade institucional da TI e do agravamento dos atritos com os órgãos de controle interno, o Comitê Diretor de TIC do CBN deliberou, no início de 2016, a implementação de uma intervenção abrangente alicerçada nas diretrizes do COBIT (TEITLER-SANTULLO, 2022). A abordagem estruturou-se em um plano de ação de cinco fases:

1. **Revisão Conceitual do COBIT:** Capacitação da liderança de TI nas premissas fundamentais de governança, princípios de alinhamento e componentes habilitadores da ISACA;
2. **Engajamento com as Áreas de Negócio:** Realização de ciclos estruturados de entrevistas diagnósticas com lideranças de aproximadamente 20 diretorias executivas de negócio, estabelecendo um canal de escuta ativa sobre as necessidades estratégicas da corporação;
3. **Análise de Lacunas (*Gap Analysis*):** Confronto criterioso entre os processos operacionais vigentes no CBN e os objetivos prescritos pelo modelo de referência do COBIT;

4. **Mapeamento Sistemático de Dores Críticas:** Catalogação minuciosa dos gargalos decisórios, sobreposições de autoridade, fontes de retrabalho e pontos críticos de atrito interdepartamental;
5. **Definição de Ações Estruturantes e Governança Compartilhada:** Reestruturação formal do Comitê de Direção de TI, que passou a ser compartilhado institucionalmente com a integração direta de cinco diretores executivos de áreas finalísticas de negócio (com destaque para Risco Corporativo, Auditoria Interna e Recursos Humanos) (TEITLER-SANTULLO, 2022).

No plano tático, a estratégia priorizou o domínio de governança **EDM (*Evaluate, Direct and Monitor*)**, articulado estreitamente aos processos de planejamento estratégico do domínio APO (TEITLER-SANTULLO, 2022). Essa reformulação instituiu uma rigorosa segregação de direitos deliberativos (WEILL; ROSS, 2006): revogou-se o canal discricionário pelo qual o conselho aprovava projetos isolados, determinando-se que qualquer demanda tecnológica passasse compulsoriamente por uma triagem colegiada de viabilidade técnica, arquitetural e financeira no comitê de governança compartilhada. Paralelamente, estabeleceu-se a gestão contínua sobre o ciclo de vida dos benefícios corporativos, rastreando o retorno pretendido desde o *business case* inicial até a mensuração de impactos operacionais no pós-implantação.

4.3.3. Mecanismos de Monitoramento e Resultados Obtidos

Para sustentar a efetividade da governança no longo prazo, o CBN estabeleceu três mecanismos perenes de monitoramento contínuo (TEITLER-SANTULLO, 2022):

- **KPIs Anuais Estratégicos:** Definição de metas formais de serviço e indicadores de entrega de valor atrelados aos objetivos do plano estratégico da instituição;
- **Comitê Mensal de Risco Integrado:** Supressão do isolamento departamental dos riscos de TI; as métricas de segurança cibernética e continuidade operacional foram incorporadas diretamente à Matriz de Risco Corporativo do banco central;
- **Avaliações Regulares de Conformidade:** Atualização periódica das políticas de governança e auditoria contínua quanto à aderência às normas financeiras nacionais e internacionais.

A Tabela 1 sintetiza o comparativo estrutural entre o cenário operacional anterior (2015) e o ambiente transformado sob o sistema de governança do COBIT.

Tabela 1. Comparativo da Governança de TI no Banco Central da Nigéria (2015 vs. Pós-COBIT)

Dimensão de Análise	Cenário Pré-COBIT (2015)	Cenário Pós-Implementação do COBIT
Postura Operacional	Reativa, dispersa e focada em “apagar incêndios” cotidianos (TEITLER-SANTULLO, 2022).	Proativa, com <i>roadmap</i> estratégico planejado e reportado sistematicamente à direção (TEITLER-SANTULLO, 2022).
Direitos Decisórios	Negócio contornava a TI (<i>shadow IT</i>) e obtinha aprovações diretas no conselho (TEITLER-SANTULLO, 2022).	Aprovação desvinculada do conselho isolado; triagem obrigatórias no comitê compartilhado de TI (TEITLER-SANTULLO, 2022; WEILL; ROSS, 2006).
Realização de Valor	Benefícios presumidos e não acompanhados após a entrega dos projetos (TEITLER-SANTULLO, 2022).	Rastreamento e acompanhamento formal de benefícios ao longo de todo o ciclo de vida (<i>business case</i> ao pós-implantação) (TEITLER-SANTULLO, 2022).
Alinhamento Estratégico	Estratégia de TI tratada de forma estanque e descompassada em relação ao negócio (TEITLER-SANTULLO, 2022).	TI incorporada como elemento nuclear no plano estratégico geral do banco (TEITLER-SANTULLO, 2022; WEILL; ROSS, 2006).
Gestão de Risco	Riscos cibernéticos e operacionais tratados como problemas técnicos isolados da TI (TEITLER-SANTULLO, 2022).	Reporte mensal regular de riscos de TI integrado diretamente à Matriz de Risco Corporativo do banco (TEITLER-SANTULLO, 2022).

Fonte: Adaptado de Teitler-Santullo (2022).

5. Conclusão

A governança corporativa de Informação e Tecnologia sob a perspectiva do COBIT 2019 consolida-se, ao longo de três décadas de evolução contínua, como um modelo essencial para que organizações contemporâneas transformem investimentos tecnológicos em valor sustentável de negócio. A separação conceitual e prática entre as funções de governança (avaliação, direcionamento e monitoramento pelo conselho e alta liderança) e gestão (planejamento, construção, operação e controle diário por gestores técnicos) estabelece fronteiras nítidas de autoridade, suprimindo sobreposições e eliminando zonas cinzentas de responsabilidade decisória.

Ao incorporar 11 Fatores de Design dinâmicos e métricas de capacidade fundamentadas na escala CMMI, o framework afasta-se definitivamente de receitas padronizadas inflexíveis. Essa arquitetura permite que a governança seja calibrada de acordo com o contexto estratégico, a intensidade regulatória e o apetite ao risco de cada instituição. Ademais, o reconhecimento de que a governança depende da articulação harmônica de sete componentes habilitadores – e não unicamente de processos – reforça a importância das estruturas organizacionais colegiadas, dos fluxos informacionais confiáveis e dos aspectos comportamentais e éticos da liderança.

O exame da interoperabilidade do COBIT 2019 comprovou sua vocação como um “guarda-chuva estratégico” (meta-modelo). O framework não busca substituir padrões

consagrados de mercado, mas atua como o elo integrador superior que orienta o direcionamento e a prestação de contas, delegando a execução tática e operacional para normas consagradas como ITIL (gestão de serviços), ISO/IEC 27001 (segurança da informação), TOGAF (arquitetura corporativa) e PMBOK (projetos).

A análise empírica do estudo de caso no Banco Central da Nigéria (CBN) ilustrou de forma contundente essa dinâmica na prática corporativa: a mera posse de certificações ISO 27001 e processos ITIL não foi suficiente para impedir o caos operacional, a proliferação de *shadow IT* e a aprovação indiscriminada de projetos sem viabilidade técnica. A virada estratégica do CBN ocorreu precisamente com a implantação do COBIT centrada no domínio EDM e na governança compartilhada com diretores executivos de negócio, instituindo triagem unificada de demandas, rastreamento de benefícios do início ao fim e integração dos riscos cibernéticos à Matriz de Risco Corporativo. Em suma, o COBIT 2019 demonstra que a tecnologia só atinge maturidade quando alinhada como ativo nuclear da governança corporativa global.

Referências

FEELY, D. Getting governance right. *Info Source*, v. 7, n. 3, 2007.

FERNANDES, A. A.; ABREU, V. F. d. *Implantando a governança de TI: da estratégia à gestão dos processos e serviços*. 4. ed. Rio de Janeiro: Brasport, 2014.

ISACA. *COBIT 2019 Design Guide: Designing an Information and Technology Governance Solution*. Schaumburg, IL: Information Systems Audit and Control Association, 2018. Acesso em: 06 out. 2026. Disponível em: <https://www.isaca.org/resources/cobit>.

ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. Schaumburg, IL: Information Systems Audit and Control Association, 2018. Acesso em: 06 out. 2026. Disponível em: <https://www.isaca.org/resources/cobit>.

ISACA. *COBIT 2019 Framework: Introduction and Methodology*. Schaumburg, IL: Information Systems Audit and Control Association, 2018. Acesso em: 06 out. 2026. Disponível em: <https://www.isaca.org/resources/cobit>.

ISO/IEC. *ISO/IEC 38500:2024: Information technology — Governance of IT for the organization*. 3. ed. Genebra: International Organization for Standardization, 2024.

TANGKA, G. M. W.; LOMPOLIU, E. Information technology governance using the COBIT 2019 framework at PT. Pelindo TPK Bitung. *CogITo Smart Journal*, v. 9, n. 2, p. 355–367, 2023.

TEITLER-SANTULLO, K. Case study: driving digital transformation through COBIT. *ISACA Journal*, v. 6, 2022. Acesso em: 06 out. 2026. Disponível em: <https://www.isaca.org/resources/news-and-trends/isaca-now-blog/2022/case-study-driving-digital-transformation-through-cobit>.

WEILL, P.; ROSS, J. W. *TI Governança: Como as Melhores Empresas Gerenciam os Direitos de Decisão de TI para Obter Melhores Resultados*. São Paulo: M. Books, 2006.